

Tackling the PCI DSS challenges

James Rees

PCI DSS has been a controversial subject for businesses and organisations in the western world for some time. There have been many complaints from a number of sources over the past few years over the exacting requirements that PCI DSS imposes on organisations that need to take card payments in order to sell their products. From the large global online retailers such as Amazon, to the small ecommerce companies attempting to make it in a volatile economy, all are required to comply with PCI DSS and many – unfortunately – do not understand it.

Experience gained from undertaking PCI DSS consultancy in many organisations of differing sizes reveals that many are fearful of the consequences of the PCI DSS requirements and their effect on the company culture. Other organisations have shown outright hatred and apathy toward PCI DSS over the cost and the implications to their working environment. And some do not see the point of PCI DSS and avidly attempt to ‘get around’ the requirements. There have been a few that have embraced PCI as a good idea, but they are in a small minority. Most firms ultimately succeed by applying a little care and attention, as well as by translating the requirements into their own particular language. Yet the road in many cases has been long and fraught with frustration.

PCI DSS in a nutshell

PCI DSS has been designed to protect people’s valuable card data from being stolen and misused. No organisation wants to be the subject of a security event where card data has been stolen – the effects are devastating in terms of both fines and clear-up costs – and there are the longer-term issues of brand damage and loss of customer confidence in the organisation. Properly implemented PCI DSS compliance that is adequately maintained should

reduce the chance of a damaging security breach. Even if the worst happens and the company still has a security issue then policies and procedures will be in place to address the security event and mitigate the issue through effective countermeasures.

“Most firms ultimately succeed by applying a little care and attention, as well as by translating the requirements into their own particular language”

Qualified Security Assessors (QSAs) hear many arguments against PCI DSS, and a quick Google search on the matter shows that there are several common themes:

- PCI DSS is too hard.
- PCI DSS is too expensive.
- PCI DSS is not a legal requirement so why do we have to?
- Some elements of PCI DSS are ok but others are too strict.
- What does ‘scope’ mean? And how do I define this? The guidelines are too vague.
- PCI DSS doesn’t apply to us we are only a small company.
- We agree with some of the PCI DSS requirements but not others.
- Why do our third parties have to prove compliance and why does their status affect ours?
- PCI DSS has no teeth, what can they do to us if we refuse?



James Rees

So let us analyse these statements in depth.

Too hard

PCI is an exacting and involved compliance model. The type of business you’re in, how you operate and how you process, store and transmit card information will have a significant effect on what items within PCI DSS you will need to undertake. For those PCI DSS requirements that you deem as not applicable in your case, as long as you can justify your reasoning as to why they are not applicable then you will be fine. PCI DSS can be as complicated or as simple as you want to make it. Yes, there will probably be some complex items to address (there always are) but don’t panic and over-complicate matters. If in doubt, ask for help from a QSA.

“You may get away with telling your acquirer or client that you are working on it, but that will only last for so long before you either get fined or lose a valuable customer”

Too expensive

Unfortunately, in some cases it is an inconvenient truth that achieving PCD DSS compliance is overly expensive. It can be a very expensive project to undertake: even for smaller firms with a smaller infrastructure it can be very costly to undertake the necessary remediation required to attain compliance. But bear

in mind, too, that fines are also expensive (and are 'dead' money too). You may get away with telling your acquirer or client (if a service provider) that you are working on it, but that will only last for so long before you either get fined or lose a valuable customer due to your inability to prove you are compliant with PCI DSS. Look at the risks and decide if you are able to create a way to undertake business without taking or facilitating card payments – then you will not need to comply with PCI.

Not a legal requirement

At the moment, only a few states in the US have begun to make PCI DSS a legal requirement. In the UK there have been discussions to support it as a legal requirement, though this will probably be a long time coming. In truth, there are likely to be no legal requirements to undertake PCI DSS. However, the standard was designed to protect consumers and the banking system from card fraud. The large card brands have decided that, in order to utilise their card brands in your business, you must have a specific level of security as laid out and communicated in the PCI DSS compliance model. This is supported by all the major banking institutions and thus, in order to do business with the banks and the card brands, it is a contractual requirement to comply with PCI DSS. The lack of any legal requirement therefore becomes moot if you can't do business without being PCI DSS compliant.

"Scoping is the one part of PCI DSS that QSAs universally agree must be correctly undertaken at the start of the project"

Some elements too strict

Even QSAs will admit that PCI DSS is a very strict compliance model.

However, it does make good sense, and it does address a number of security concerns that information security people have been concerned about for some time. In today's world the use of cold hard cash is rapidly diminishing in the developed world. Using cards to pay for goods is easier, quicker and universally accepted with the minimum of fuss – it is the way the global marketplace is going and there is no stopping it. The strict nature of PCI DSS is there to protect people, businesses and the financial institutions from fraud. Card fraud in the modern world is a massive criminal business revenue stream and something has to be done about it.

"Without a correctly undertaken and regularly reviewed scope, complying with PCI DSS will be extremely difficult"

Guidelines too vague

The PCI DSS guidelines are specific in their requirements and how scoping works. It should be recognised however that scoping, in particular, is a fine art in itself. If you or people within your organisation feel that the guidelines are too vague, it is a clear signal that the organisation needs to have some form of professional support from a QSA and/or Internal Security Assessor (ISA). Scoping is the one part of PCI DSS that QSAs universally agree *must* be correctly undertaken at the start of the PCI DSS project. Without a correctly undertaken and regularly reviewed scope, complying with PCI DSS will be extremely difficult. The golden rule for PCI DSS is always 'get the scope right'. The key rules of scoping are:

- If a system, service or location stores, transmits or processes card payments then it is clearly in line for PCI DSS compliance.
- If a system, service or location connects directly to another system or service

that stores, transmits or processes card payments then it is also clearly in line for PCI DSS compliance.

- If a system or service indirectly connects to a system, service or location that stores, transmits or processes card payments then it is *potentially* in line for PCI DSS compliance, depending on the indirect connection.

Getting the scope correct in any PCI DSS project is the most important part of the process; if this is not done correctly it can have a seriously detrimental effect on the compliance process as a whole.

Only a small company

Unfortunately, even if you are a very small firm, if you take card payments from clients – be it just one, or a few million – you are required to comply with PCI DSS. There are no distinctions in PCI DSS for large companies or small companies. If you take card payments then you are required to comply even if it is only one card payment. You are contractually obliged with the bank and the card brands through the merchant ID contractual agreement.

"Spend time selecting the right QSA for your organisation. Some are more experienced than others and opinions and interpretations of PCI DSS can differ"

Agreeing with some requirements

This is something that happens a lot – organisations don't see the value of some parts or a small section of the PCI DSS requirements. Thus occasionally you will see or hear the opinion that they need to worry only about those parts of PCI DSS with which they agree. Unfortunately PCI DSS requires that *all* of the requirements applicable to the organisation seeking compliance must be met. You cannot pass PCI DSS without

all components applicable to the organisation being in place.

Third parties

Under PCI DSS it is perfectly acceptable to engage third-party organisations to undertake card payment facilities on the organisation's behalf. However, be warned that all third parties involved in the process will need to prove their compliance via the availability of an Attestation of Compliance (AoC).

"Companies that have been fined are usually very secretive about those fines. They will also keep the news of the breach as quiet as possible as to prevent brand damage"

PCI DSS compliance is the responsibility of the merchant, which also needs to ensure that all service providers can prove compliance. Failure to do so will mean that the merchant cannot comply with PCI DSS and thus will not be considered to be PCI DSS compliant.

What can they do to us?

Rest assured, PCI DSS has some serious teeth on the part of the card brands and the banks. The acquiring banks reserve the right to fine, increase the cost per transaction or, as an ultimate sanction, refuse entirely to allow a merchant to take card payments.

"PCI DSS does not have to be difficult. Yes, it has components that are often challenging to achieve, but in reality PCI DSS should be a part of normal business procedures, not an independent requirement"

Companies that have been fined are usually very secretive about those fines. They will also keep news of the breach as quiet as possible as to prevent brand

damage. No company wants to be plastered all over the media with stories of losing people's confidential data. So, just because you haven't heard much about firms suffering as a result of non-compliance, don't assume it isn't happening.

Key factors for compliance

So let's review the things to be aware of when seeking to become PCI DSS compliant.

Get your PCI DSS scope right, this is the most important part of any PCI DSS project bar none – you must get this correct.

Third parties being brought into outsource parts of the PCI DSS scope should be carefully checked before being brought on board. Many will say they are PCI DSS compliant – unfortunately many are not. Ensure you request a copy of the AoC before you engage their services.

PCI DSS has to be maintained. Do not complete the project and forget about the requirements until the next year. Review and maintain PCI DSS over the whole year. Identify and address any issues as and when they occur – do not leave them for later.

PCI DSS does not have to be difficult. Yes, it has components that are often challenging to achieve, but in reality PCI DSS should be a part of normal business procedures, not an independent requirement. Almost all of the security requirements contained within the compliance model are considered to be best practice.

If you are a service provider or merchant taking card payments, you will need to prove PCI DSS compliance. Do not try to get around it – you will not succeed. Many have tried and many have failed.

Significant changes to the network infrastructure require retesting of vulnerability scanning, scans by an Approved Scanning Vendor (ASV) and penetration testing. Most of these can be done in-

house but the person conducting them must be trained. A QSA will check during an audit: failure to provide these will result in a fail.

You are required to have a knowledgeable and trained member of staff with regards to information security. This means they must have experience in dealing with information security (not IT security, which is only a small part of the picture). This role can be outsourced if need be, but the organisation seeking to become PCI DSS compliant must have access to this skillset in some fashion.

"If you are required to have a QSA review and sign off your PCI DSS compliance, spend time selecting the right QSA for your organisation"

If you are required to have a QSA review and sign off your PCI DSS compliance, spend time selecting the right QSA for your organisation. Some are more experienced than others and opinions and interpretations of PCI DSS can differ. Select your QSA wisely.

In addition, most QSAs in the UK will cost you about £1,000 per day. Be prepared to pay a premium for the services of a good QSA. There are some that offer services at a much lower cost but experience has proved that these QSA companies are not particularly helpful. Don't forget, it is commonly the fact that you get what you pay for. Spend time finding the right QSA as you will be working with them extensively.

About the author

James Rees is the chief information security officer of Razor Thorn Security (www.razorthorn.co.uk), specialising in PCI DSS, risk management and cyber-warfare. He has consulted and been an advisor on information security for some of the largest and most complex organisations in the world.